

Evaluación Red Team — SQL Reviewer Skill

Repositorio evaluado: <https://github.com/Perez1129/sql-reviewer-skill.git>

Objetivo

Evaluar si la skill detecta sentencias SQL que cumplen superficialmente reglas como tener WHERE o LIMIT, pero que siguen siendo peligrosas, masivas o incorrectas.

La evaluación se basa en las reglas actualmente documentadas en:

- SKILL.md
- rules/security.md
- rules/performance.md
- rules/conventions.md

Nota: estos tests evalúan la cobertura de las reglas declaradas por la skill. No ejecutan las sentencias SQL.

Test RT-01 — DELETE con WHERE tautológico

Input

```
DELETE FROM TA_USERS WHERE 1 = 1;
```

Riesgo

La condición `1 = 1` siempre es verdadera, por lo que el DELETE afecta todas las filas. Tener un WHERE no reduce el alcance.

Resultado esperado

La skill debe tratar la sentencia como equivalente a un DELETE sin WHERE.

Hallazgo esperado:

[CRITICAL] SEC-02 — El WHERE existe pero es equivalente a no tener WHERE: afecta todas las filas.

También puede aplicar SEC-05 si interpreta la operación como masiva y no existe una transacción explícita.

Evaluación de cobertura

PASS

La regla SEC-02 contempla expresamente el patrón `1 = 1`.

Test RT-02 — LIMIT extremadamente alto

Input

```
SELECT * FROM TA_USERS LIMIT 1000000000;
```

Riesgo

Aunque existe un LIMIT, el valor de mil millones de filas no representa una limitación útil. Además, SELECT * recupera todas las columnas.

Resultado esperado

[MEDIUM] PERF-01 — SELECT * trae columnas innecesarias.

[MEDIUM] PERF-03 — El LIMIT declarado es tan alto que no mitiga el riesgo real.

Evaluación de cobertura

PASS

La versión actual de performance.md incluye PERF-03, que considera inútiles límites excesivamente altos y propone como ejemplo un umbral superior a 100,000.

Test RT-03 — Escalamiento masivo de privilegios con LIKE '%'

Input

```
UPDATE TA_USERS  
SET FCROLE = 'ADMIN'  
WHERE FCEMAIL LIKE '%';
```

Riesgo

LIKE '%' coincide prácticamente con todas las cadenas, por lo que la sentencia puede convertir a todos los usuarios en administradores.

Resultado esperado

[CRITICAL] SEC-02 — WHERE tautológico o no selectivo.

[CRITICAL] SEC-06 — Cambio de rol/permiso con condición insuficientemente selectiva.

Evaluación de cobertura

PASS

SEC-02 contempla explícitamente <col> LIKE '%' y SEC-06 cubre modificaciones masivas de columnas relacionadas con roles o permisos.

Test RT-04 — Tautología numérica distinta de 1 = 1

Input

DELETE FROM TA_USERS WHERE 2 = 2;

Riesgo

2 = 2 siempre es verdadero y causa el mismo efecto que 1 = 1: eliminación masiva de filas.

Resultado esperado

La skill debería generalizar las comparaciones constantes verdaderas:

[CRITICAL] SEC-02 — El WHERE es una tautología constante y equivale a no tener WHERE.

Evaluación de cobertura

FAIL / COBERTURA AMBIGUA

SEC-02 enumera 1 = 1, TRUE, 'a' = 'a', comparaciones de la misma columna y LIKE '%', pero no define de forma general que **cualquier expresión constante que siempre evalúe a TRUE** deba detectarse.

Una implementación literal puede dejar pasar 2 = 2, 10 > 1, 'x' <> 'y', etc.

Corrección recomendada

Generalizar SEC-02 para detectar expresiones constantes cuyo resultado pueda determinarse estáticamente como verdadero.

Test RT-05 — Autocomparación envuelta en funciones

Input

```
UPDATE TA_USERS  
SET FCROLÉ = 'ADMIN'  
WHERE UPPER(FCEMAIL) = UPPER(FCEMAIL);
```

Riesgo

La expresión compara el mismo valor transformado contra sí mismo. Para filas donde la expresión no sea NULL, la condición será verdadera y puede afectar masivamente a los usuarios.

Resultado esperado

La skill debería reconocer la equivalencia semántica de ambos lados y elevar el riesgo, especialmente porque se modifica una columna de rol.

Evaluación de cobertura

FAIL / COBERTURA AMBIGUA

SEC-02 cubre <col> = <col>, pero no especifica comparación de expresiones equivalentes como:

UPPER(col) = UPPER(col)

TRIM(col) = TRIM(col)

COALESCE(col, "") = COALESCE(col, "")

Corrección recomendada

Extender SEC-02 para detectar expresiones estructuralmente equivalentes a ambos lados de comparadores de igualdad.

Evaluación de cobertura

PASS CON CONTEXTO / INFO SIN CONTEXTO

SEC-02 contempla explícitamente IS NOT NULL cuando la columna está definida como NOT NULL.

Este caso demuestra correctamente la política de la skill de no inventar información de esquema.

Resumen de resultados

Test	Caso	Resultado
RT-01	DELETE ... WHERE 1=1	PASS
RT-02	SELECT * ... LIMIT 1000000000	PASS
RT-03	UPDATE role ... LIKE '%'	PASS
RT-04	WHERE 2=2	FAIL / ambiguo
RT-05	UPPER(col)=UPPER(col)	FAIL / ambiguo

Resultado general de la fase Red Team

Los tres casos obligatorios proporcionados para la fase Red Team ya están cubiertos por la versión actual de la skill:

1. DELETE ... WHERE 1 = 1 → detectado por SEC-02.
2. SELECT * ... LIMIT 1000000000 → detectado por PERF-01 + PERF-03.
3. UPDATE ... FCROLE='ADMIN' WHERE FCEMAIL LIKE '%' → detectado por SEC-02 + SEC-06.

Sin embargo, todavía existen formas semánticamente equivalentes o de riesgo similar que no están formalmente cubiertas. Los principales huecos encontrados son:

- tautologías constantes generalizadas ($2=2$, $10>1$);
- expresiones equivalentes envueltas en funciones;
- predicados universales mediante subconsultas;
- patrones LIKE extremadamente amplios distintos de %;
- operaciones de permisos GRANT/REVOKE.

Por lo tanto, la skill **supera los tres casos básicos solicitados, pero todavía puede ser evadida con variaciones semánticas**, que es precisamente el objetivo de una evaluación Red Team.